

SUMUP x OWASP · SOFIA CHAPTER

Welcome!

Glad to have you at the June
meetup. Grab a coffee and settle
in.

- > Doors 18:30 · Talks 19:00 → 21:30
- > SumUp Office · BSR-2 · Sofia



OWASP Sofia: June 2026 Meetup

June 25, 2026 | 19:00

SumUp Office | BSR-2

str. Nikola Tesla 5, Sofia



ABOUT SUMUP

4,000+ SumUppers

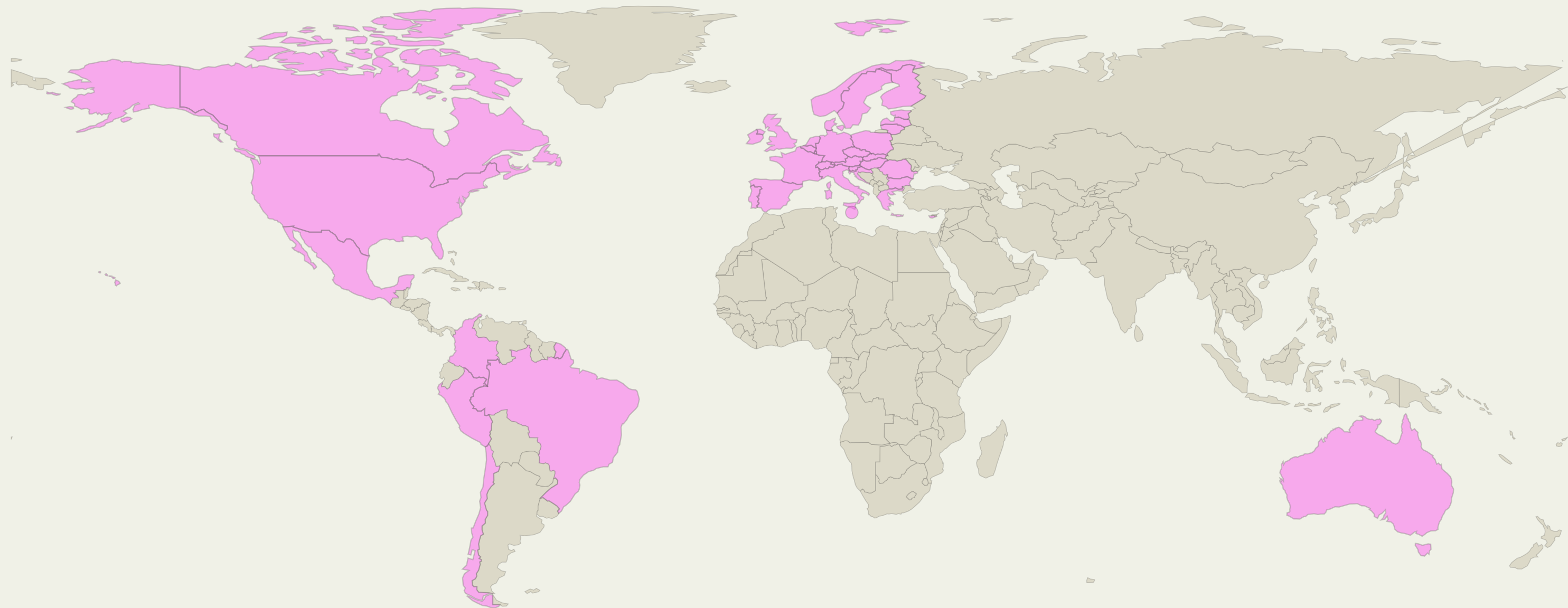
Building the payment and business tools small merchants love - live in **38 markets** across Europe, the Americas and Australia.



YOUR HOST TODAY

Deyan Vuchev

Cybersecurity Architect
@ SumUp

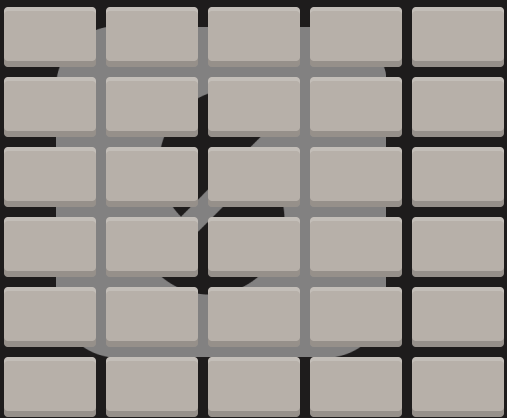


● Markets we operate in | 30 Europe • 7 Americas • 1 Australia

MEETUP AGENDA

How the evening runs

18:30 – 19:00	Registration, networking & coffee	DOORS OPEN
19:00 – 19:15	Chapter opening · host & company intro	WELCOME
19:15 – 20:00	AI Security at the Fintech Frontier Deyan Vuchev @ SumUp Up next	
20:00 – 20:45	Detected ≠ Exploitable: Rethinking Vulnerability Prioritization Denitsa Taneva @ Wisebee	TALK
20:45 – 20:55	Break	PAUSE
20:55 – 21:40	It’s about Time Vladimir Atanasov @ EGT	TALK
21:40 – 22:00	Networking and panel closure	CLOSING



AI Security at the Fintech Frontier.

Deyan Vuchev
Cybersecurity Architect · SumUp

THE THREAT SURFACE

Why fintech changes the AI threat model

Frontier models compress vulnerability-to-exploit from **months to hours**, at near-zero cost. The difference here is what sits inside the blast radius.

01

Regulated data

Cardholder data, PII and financial records sit under GDPR and the financial-sector regimes. Classification has to happen *before* anything reaches a model.

02

Real money movement

Agent actions can move funds and are often irreversible. A manipulated agent causes harm at machine speed - with no human in the step.

03

Adversarial incentive

The payoff is money, not bragging rights. Attackers are funded and patient - and agentic ones have unlimited patience at near-zero per-attempt cost.

THE SURFACE NOW SPANS THE WHOLE AI LIFECYCLE

Training data



Model supply chain



Inference endpoints



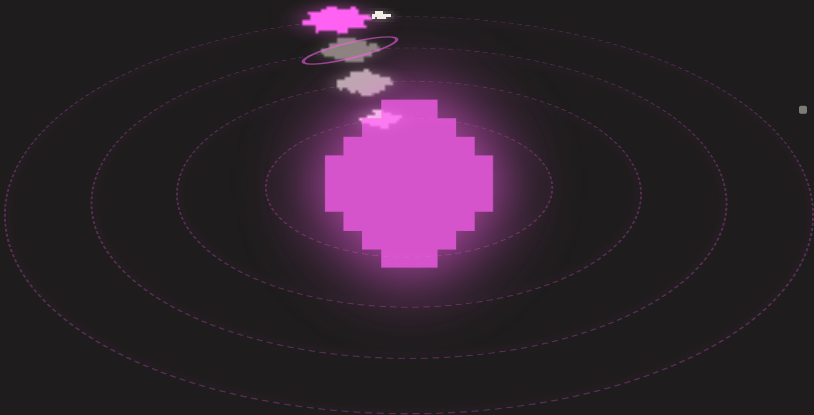
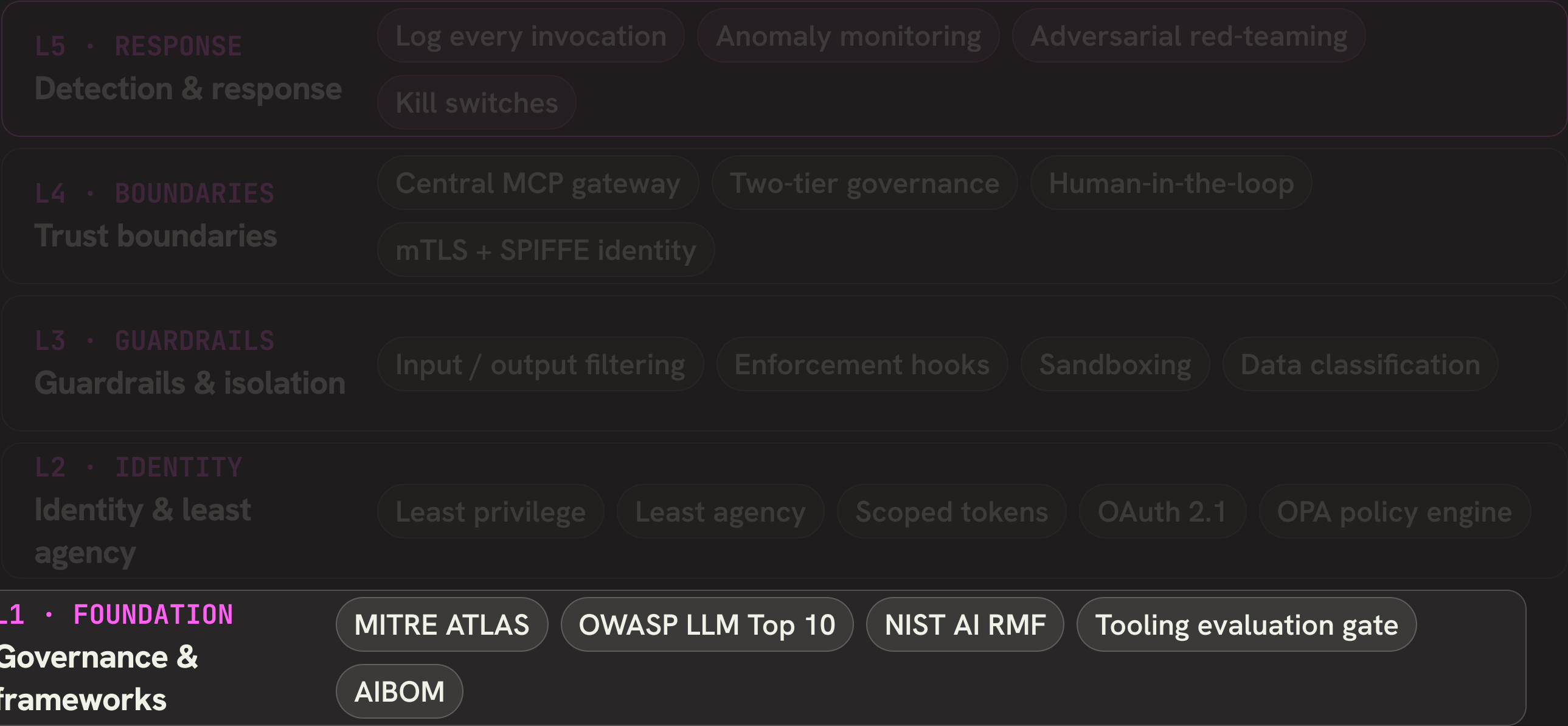
Agentic workflows

Our AI security center of gravity

MITRE ATLAS

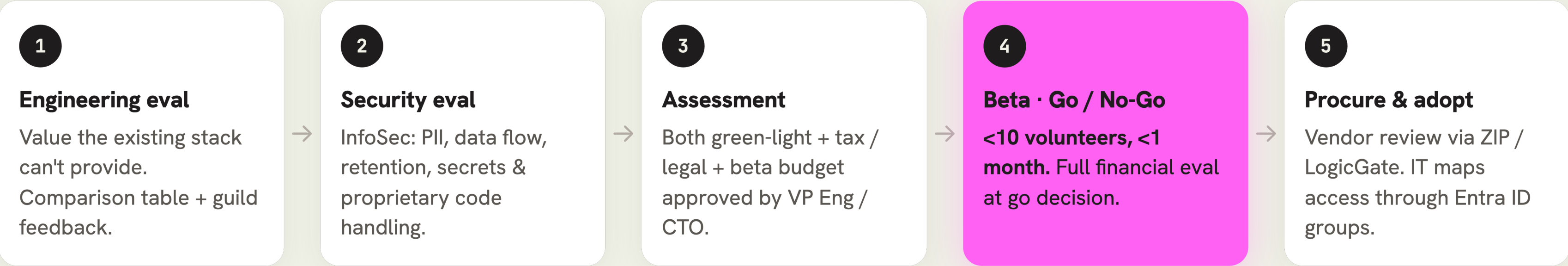
OWASP LLM Top 10

NIST AI RMF



Tooling evaluation gate

Every AI engineering tool clears engineering *and* security review before it touches our code or data.



IN PRACTICE Hardening the AI-enabled IDEs developers use - e.g. Cursor

LIVE

Block **unsigned plugins** from the OpenVSX marketplace.

LIVE

A **15-day cooldown** on new plugin versions before they can be installed.

COMING

A centrally **MDM-managed plugin allowlist** - cutting off supply-chain attacks via plugins.

Denial is enforced | **CrowdStrike Falcon** blocks locally-installed tools · SaaS access is monitored by HTTP traffic inspection, with logged reach-out if a restricted tool is used.

One MCP gateway, two tiers

Every MCP call - internal copilot, customer agent, or third-party - routes through one enforcement point before it reaches any service or data.

1 · CALLERS

- Internal copilot
Tier 1
- Customer-facing agent
Tier 2
- Third-party MCP
gateway-managed trust



2 · MCP GATEWAY · single enforcement point

- AuthN / AuthZ
- Rate limiting
- Schema validation
- Tool registry
- Full audit
- Response redaction



3 · SERVICES & DATA

- Service + thin MCP adapter
no business logic
- REST APIs · data stores
mTLS · SPIFFE



PROPORTIONATE CONTROLS · TWO TIERS

TIER 1 Internal

- Corporate SSO · standard RBAC
- Standard audit · rate limits
- No PII, no transactional data
- Lighter, not ungoverned - launches first

TIER 2 External

- OAuth 2.1 · fine-grained OPA policy
- Full audit · decision reconstructability
- Response redaction · graduated PII
- Full agent guardrails · DORA / PSD2 / GDPR

Guardrails for autonomous agents

Every tool is safety-classified, and external agents run inside hard limits the gateway enforces.

safe
Read-only, no PII

Free within rate limits

sensitive
Returns PII or confidential data

Needs data-access grant

mutating
Creates, updates or deletes

Write permission + guardrails

dangerous
Financial, irreversible

Human-in-the-loop

RISK CLASSIFICATION

HUMAN REVIEW →

safe	sensitive	mutating	dangerous
------	-----------	----------	-----------

EXECUTION LIMITS · TIER 2

10

tool-chain depth

3

mutations / session

5m

max session

€

per-session cost

Replay protection: a unique execution ID and idempotency-key dedup on every call.

EXECUTION MODES

Sandbox

→

Supervised

→

Autonomous

New agents start in sandbox and graduate only with InfoSec sign-off.

Classic software bugs, new blast radius

10 disclosed MCP CVEs across 2025–2026, by class. Almost all are old-school flaws - not novel AI attacks.

Path traversal / boundary escape Filesystem · Git reference servers		4
DNS rebinding (localhost) TypeScript SDK · Python SDK		2
Command injection mcp-server-kubernetes · Figma MCP		2
Unauthenticated RCE MCP Inspector		1
Malicious repo config → RCE Cursor CLI · .cursor/mcp.json		1

The defense is unglamorous: patch aggressively, sandbox write-capable servers, and never auto-trust repository-defined MCP config.

MAPPING

Controls × the OWASP LLM Top 10

LLM01 Prompt Injection

LLM02 Sensitive Information Disclosure

LLM03 Supply Chain

LLM04 Data & Model Poisoning

LLM05 Improper Output Handling

LLM06 Excessive Agency

LLM07 System Prompt Leakage

LLM08 Vector & Embedding Weaknesses

LLM09 Misinformation

LLM10 Unbounded Consumption

LLM01 L3 · Guardrails & isolation

Prompt Injection

Malicious or unintended inputs manipulate the model's behavior - bypassing guidelines, leaking data, or triggering unauthorized actions. Both direct and indirect vectors.

OUR MITIGATIONS

- + Constrain behavior via system prompts
- + Gateway input sanitization & anomaly detection
- + Segregate untrusted external content
- + Human approval for high-risk actions

What we've learned at the frontier

01

Impossible, not tedious

Prefer controls that remove a capability over ones that add friction. Agentic attackers have unlimited patience and near-zero per-attempt cost.

02

Design for model evolution

Today's capability is a poor predictor of tomorrow's. Build defenses resilient to behavior the model hasn't shown yet.

03

The boring bugs still win

Most real compromise is command injection, path traversal and weak auth. Patch and sandbox before chasing exotic AI threats.

04

Least agency is the lever

Scope what each tool can do, how often and where - and keep a human on irreversible actions. Where next: the central MCP gateway - Tier 1 internal first (Q3 2026), Tier 2 external to follow.

THE QUESTION FOR THE PANEL

Which AI actions still need a human to approve them - and which risks can we design out entirely?

Keep a human in the loop for the high-stakes, irreversible actions - and design the risk away everywhere else, so it never reaches a person.

Across all five layers

Governance

Least agency

Guardrails

Trust boundaries

Detection & response



Thank you.

Questions, war stories, disagreements - all welcome. Let's keep the conversation going.